

FocusBuddy

Full Production Audit Report

FAANG-Level Deep Code Review • Security Audit • Production Readiness

Auditor Roles	Principal Architect • Senior Code Reviewer • Security Auditor • Production Readiness Engineer • QA Lead
Scope	89 source files across 36 directories — every file inspected line-by-line
Date	March 15, 2026
Classification	CONFIDENTIAL

Executive Summary

Production Readiness Score

24 / 100

FocusBuddy is **NOT production ready**. The codebase has strong architectural bones — clean separation of concerns, proper Zustand stores, NativeWind styling, and a well-structured Supabase backend. However, the audit uncovered **13 CRITICAL**, **30 HIGH**, **27 MEDIUM**, and **29 LOW** issues across security, correctness, mock code, test coverage, and infrastructure.

Three most dangerous findings:

- **Webhook signature verification is bypassable** — anyone can forge subscription events
- **Zero test coverage** — not a single test file exists in the repository
- **Core features are stubs** — payroll, data export, delete account, and restore purchases are non-functional

Severity	Count	Key Examples
[CRITICAL] CRITICAL	13	Webhook bypass, zero tests, no CI/CD, race conditions, stub features
[HIGH] HIGH	30	Prompt injection, CORS *, hardcoded state, no monitoring
[MEDIUM] MEDIUM	27	Type mismatches, unbounded queries, missing validation
[LOW] LOW	29	Placeholder icons, dead code, accessibility issues

Table of Contents

- 1. Codebase Overview**
- 2. Architecture Analysis**
- 3. Production Readiness Score Breakdown**
- 4. CRITICAL Issues (13)**
- 5. HIGH Issues (30)**
- 6. MEDIUM Issues (27)**
- 7. LOW Issues (29)**
- 8. Mock / Stub / Placeholder Code**
- 9. Security Risk Register**
- 10. Test Coverage Analysis**
- 11. Performance Risks**
- 12. Refactoring Recommendations**
- 13. Files That Must Be Fixed**
- Verdict**

1. Codebase Overview

Repository Structure

FocusBuddy/	
app/	# 16 screens + 3 layouts (Expo Router)
(auth)/	# Sign In, Sign Up, Forgot/Reset Password
(onboarding)/	# Goal Setup, Notification Time, Trial
(tabs)/	# Home, Chat, Progress, Settings
[standalone]	# Timer, Check-In, Promises, etc.
src/	
components/	# 22 components
hooks/	# useTimer, useAppState
lib/	# supabase client, mmkv
services/	# 11 service files
stores/	# 5 Zustand stores
types/ + utils/	# Types, constants, time
supabase/	
functions/	# 3 Edge Functions
migrations/	# 1 SQL migration
components/	# Legacy scaffold (unused)
[config files]	# package.json, tsconfig, etc.

Tech Stack

Layer	Technology
Framework	React Native (Expo SDK 55), Expo Router v3
Styling	NativeWind v4 (Tailwind CSS)
Backend	Supabase v2 (Postgres, Auth, RLS, Edge Functions)
State	Zustand v5 (client), MMKV (timer persistence)
AI	OpenAI GPT-4o-mini via Supabase Edge Functions (Deno)
Payments	RevenueCat (declared but NOT configured)
Language	TypeScript (strict enabled but never executed)

File Count

Category	Count
Screen files (.tsx)	19

Category	Count
Component files (.tsx)	23
Service files (.ts)	11
Store files (.ts)	5
Hook files (.ts)	2
Edge Functions (.ts)	3
SQL Migrations	1
Config files	11
Legacy scaffold files	6
Test files	0
CI/CD files	0
Total source files	89

2. Architecture Analysis

Pattern: Feature-based monolith with service layer

```
Screens (app/) → Stores (src/stores/) → Services (src/services/) → Supabase Client (src/lib/)
Edge Functions (supabase/functions/) handle server-side AI and webhook processing.
Components (src/components/) are presentation-only with props-based data flow.
```

Strengths

- Clean separation between UI, state management, and data access
- Consistent use of type aliases for Supabase compatibility
- Proper use of `useFocusEffect` for screen-focus data refresh
- MMKV for synchronous timer persistence across app states
- Secure auth token storage via `expo-secure-store` (iOS Keychain / Android Keystore)

Weaknesses

- Duplicate timer logic in `useTimer` hook AND `sessionStore` (divergent implementations)
- Client-side writes to security-sensitive tables (subscriptions, profiles with `trust_score`)
- No data validation layer between UI and services
- Fire-and-forget async calls with no error handling in critical paths
- Legacy scaffold code cluttering the root components/ directory

3. Production Readiness Score Breakdown

Category	Weight	Score	Notes
Security	25%	15/100	Webhook bypass, CORS *, prompt injection, no input validation
Correctness	20%	30/100	Delete account broken, data export stub, streaks never update
Test Coverage	15%	0/100	Zero tests
Infrastructure	15%	5/100	No CI/CD, no monitoring, no linting
Performance	10%	50/100	Unbounded queries, render-phase side effects
Code Quality	10%	55/100	Good structure, but stubs, dead code, type mismatches
UX Completeness	5%	35/100	Placeholder icons, stub handlers, non-functional paywall
TOTAL	100%	24/100	

4. CRITICAL Issues (13)

[CRITICAL] These issues **must be fixed before any release**. Each represents a security vulnerability, data integrity risk, or completely broken core feature.

C1. Webhook Signature Verification Bypassable

File: supabase/functions/revenuecat-webhook/index.ts:73-82

Risk: If REVENUECAT_WEBHOOK_SECRET is unset, the entire signature check is skipped. Any actor can POST fabricated events to upgrade/expire subscriptions.

Fix: Fail-closed — reject all requests when secret is absent.

C2. Zero Test Coverage

File: Entire repository

Risk: No unit tests, integration tests, or E2E tests exist. No test framework is installed.

Fix: Install jest-expo, @testing-library/react-native. Write tests for auth, subscriptions, timer, and edge functions.

C3. No CI/CD Pipeline

File: Missing .github/workflows/, eas.json

Risk: No automated type checking, linting, testing, or builds. All releases are manual with no audit trail.

Fix: Add GitHub Actions workflow + EAS build configuration.

C4. TOCTOU Race on Rate Limit Check

File: supabase/functions/ai-chat/index.ts:92-123

Risk: Rate limit is checked non-atomically (read → call OpenAI → update counter). Concurrent requests bypass the limit.

Fix: Atomic Postgres counter increment with embedded check.

C5. Race Condition on Shield Award (Double-Award Exploit)

File: src/services/shields.service.ts:7-13

Risk: Read-modify-write without locking allows concurrent requests to award multiple shields.

Fix: Single atomic SQL UPDATE with conditional increment via RPC.

C6. Race Condition on Shield Usage (Negative Balance)

File: src/services/shields.service.ts:17-24

Risk: Same read-modify-write pattern allows double-spending shields.

Fix: Atomic UPDATE ... WHERE streak_shields > 0 RETURNING.

C7. Webhook Events Not Deduplicated

File: supabase/functions/revenuecat-webhook/index.ts:115-128

Risk: No event_id tracking. Retried webhooks cause duplicate processing.

Fix: Add webhook_events table with unique event_id.

C8. billing_issue Status Not in DB Enum or TypeScript Union

File: revenuecat-webhook:177, src/types/database.ts:132

Risk: Webhook writes a status value the client code cannot handle. Silent failure.

Fix: Add 'billing_issue' to union type and add DB CHECK constraint.

C9. check_in_id: " — Empty String as UUID Foreign Key

File: src/stores/sessionStore.ts:90

Risk: Empty string is not a valid UUID. Insert will fail or corrupt FK relationships.

Fix: Pass null explicitly, or require actual check_in_id.

C10. Subscription Inserted From Client (No Server Validation)

File: app/(onboarding)/trial-confirmation.tsx:42-51

Risk: Client directly inserts subscription rows. Any user can forge entitlements.

Fix: Move subscription creation server-side (Edge Function).

C11. Delete Account Does Not Actually Delete Data

File: app/delete-account.tsx:25-32, src/services/profile.service.ts:72-82

Risk: Only renames display_name to [deleted]. No data deleted. GDPR/CCPA violation.

Fix: Implement actual soft-delete with deleted_at column + backend deletion job.

C12. Data Export Is a Complete Stub

File: app/data-export.tsx:34-43

Risk: Fetches data, logs count to console, shows success message. Data is never exported.

Fix: Wire to backend export endpoint or generate downloadable file.

C13. update_streak Postgres Function Never Called

File: supabase/migrations/001_initial_schema.sql:280-320

Risk: The streak update function exists but has no trigger and no RPC caller. Streaks never update. Core feature is silently broken.

Fix: Add a trigger on daily_check_ins insert, or call via RPC after check-in.

5. HIGH Issues (30)

[HIGH] These issues represent significant risks that **must be fixed before production deployment**.

#	File	Issue
H1	All Edge Functions:4	CORS wildcard Access-Control-Allow-Origin: *
H2	ai-chat/index.ts:200	Prompt injection via unsanitized user data in system prompt
H3	profile.service.ts:22	Client can overwrite trust_score, streak_shields, current_streak
H4	profile.service.ts:72	deleteAccount writes updated_at not deleted_at
H5	chatStore.ts:191	Client-side rate limit (30/hr) resets on restart
H6	chat.service.ts:56	deleteMessage has no user_id ownership filter
H7	goals.service.ts:55	archiveGoal has no user_id filter
H8	sessions.service.ts:108	getSessionStats unbounded query (no .limit())
H9	ai-checkin/index.ts:297	Tasks inserted with null check_in_id on error
H10	ai-checkin/index.ts:281	Full system prompt stored in DB per row
H11	ai-chat:210, ai-checkin:222	No OpenAI request timeout (no AbortController)
H12	paywall.tsx:22-29	Purchase and restore handlers are stubs
H13	settings.tsx:202-204	isSubscribed = false hardcoded
H14	_layout.tsx:98-105	require('expo-router') inside setTimeout
H15	timer.tsx:45-79	No staleness check on restored MMKV timer
H16	progress.tsx:784	ListHeaderComponent called (not passed) — re-renders on scroll
H17	index.tsx:163-188	Optimistic task toggle race on rapid double-tap
H18	shame-emergency.tsx:258	fetchEvidence() called during render
H19	check-in.tsx:380-400	Components defined inside body — unmount/remount
H20	sign-up.tsx:33-36	No email format validation
H21	progress.tsx:244-247	getSessionTaskName returns UUID substring
H22	.gitignore:34	.env not protected (only .env*.local ignored)
H23	RevenueCat SDK	Purchases.configure() missing from app entry

#	File	Issue
H24	No monitoring	No Sentry/Bugsnag/Datadog integration
H25	No linter/formatter	No ESLint, Prettier, or Husky hooks
H26	package.json	Unused @react-native-async-storage/async-storage
H27	settings.tsx:238-240	Notification Time opens Alert stub
H28	settings.tsx:322	Manage Subscription handler is () => {}
H29	settings.tsx:354-357	Restore Purchases shows Alert only
H30	settings.tsx:198-199	Privacy toggles not persisted

6. MEDIUM Issues (27)

#	File	Issue
M1	auth.service.ts:13	Duplicate profile creation (service + DB trigger)
M2	profile.service.ts:44	completeOnboarding not idempotent
M3	promises.service.ts:96	Trust score not persisted atomically
M4	checkin.service.ts:42	Unbounded days parameter
M5	config.toml:42	Email confirmations disabled
M6	schema:85 / database.ts:80	pauses column type mismatch (JSONB vs number)
M7	ai-chat/index.ts:116	No message length validation
M8	sessions.service.ts:84	getRecentSessions returns active sessions
M9	useTimer.ts + sessionStorage.ts	Duplicate divergent timer logic
M10	time.ts:31	getRelativeTime crashes on invalid date
M11	_layout.tsx:55-66	router missing from useEffect deps
M12	check-in.tsx:304-331	State update after navigation
M13	promises.tsx:127-146	handleBroken reason never stored
M14	session-rating.tsx:96	No redirect to sign-in on expired session
M15	chat.tsx:25-31	WELCOME_MESSAGE timestamp stale
M16	BottomSheet.tsx:32-37	Backdrop press propagation
M17	useColorScheme.web.ts	Always returns 'light'
M18	notification-time.tsx:65	Non-null assertions on nullable values

#	File	Issue
M1 9	timer.tsx:45-79	Missing useEffect dependencies
M2 0	data-export.tsx:43	PII (userId) logged to console
M2 1	package.json	TypeScript ~5.9.2 may not exist
M2 2	package.json	react-native-worklets as direct dep
M2 3	app.json:54	EAS projectId is placeholder
M2 4	package.json	No typecheck or lint scripts
M2 5	All services	No retry logic on external calls
M2 6	Edge Functions	No structured logging
M2 7	constants.ts	Three different rate limit values

7. LOW Issues (29)

#	File	Issue
L1	constants.ts:14	CHAT_RATE_LIMIT unused
L2	constants.ts:11	TIMER_MILESTONES unused
L3	time.ts:4	formatTimer unguarded for negative input
L4	revenuecat-webhook:121	existingEvent query unused
L5	authStore.ts:63	fetchProfile fire-and-forget unhandled rejection
L6	sessionStore.ts:143	pause/resume DB updates swallow errors
L7	useAppState.ts:31	Callback deps cause listener churn
L8	schema:51	energy_level nullable but TS non-null
L9	schema:98 / database.ts:91	'system' role in TS but not DB CHECK
L10	sessionStore.ts:241	restoreTimerFromMMKV no user_id guard
L11	+not-found.tsx	Uses legacy Themed components
L12	(tabs)/_layout.tsx:41-103	Tab icons are single letters (H, P, C, S)
L13	GreetingHeader.tsx:39	Placeholder [fire] text
L14	StatCards.tsx:15,23	Placeholder [T], [S] text
L15	GoalCard.tsx:55	Placeholder [ok] text
L16	ActivityFeed.tsx:34-42	Placeholder [>], [v], [!] text
L17	QuickActions.tsx:31-50	Placeholder [>], [*], [C], [P] text
L18	progress.tsx:419	Array index as key
L19	shame-emergency.tsx:233,355	Array index as key
L20	bad-day-toolbox.tsx:146	Array index as key
L21	paywall.tsx:72	Array index as key
L22	index.tsx:193-209	as any type casts on route paths
L23	GreetingHeader.tsx:27-28	Date functions on every render
L24	TaskBreakdown.tsx:28-29	Fragile .split(' ') on Tailwind class

#	File	Issue
L25	ProgressBar.tsx:27-32	animatedWidth in useEffect deps
L26	Avatar.tsx:29-38	No onError for broken images
L27	Card.tsx:38	accessibilityLabel undefined when no header
L28	LoadingScreen.tsx:12	accessibilityRole='alert' interrupts readers
L29	Legacy components/ dir	Scaffold files likely unused

8. Mock / Stub / Placeholder Code

■ **NOT PRODUCTION READY** — The following 16 locations contain mock, stub, or placeholder implementations that will break the user experience or misrepresent functionality.

Location	What's Mocked	Must Replace With
paywall.tsx:22-29	Purchase handler → router.back()	RevenueCat Purchases.purchaseProduct()
paywall.tsx:26-29	Restore handler → () => {}	RevenueCat Purchases.restorePurchases()
settings.tsx:202	isSubscribed = false	subscriptionStore.isSubscribed
settings.tsx:204	renewalDate = 'April 15, 2026'	Actual current_period_ends
settings.tsx:238-240	Alert('Time picker would open here')	Date/time picker component
settings.tsx:322	Manage Subscription → () => {}	App Store management URL
settings.tsx:354-357	Restore Purchases → Alert	RevenueCat restore flow
settings.tsx:198-199	Privacy toggles (no persistence)	Profile field persistence
data-export.tsx:34-43	console.log(count)	Backend export endpoint
delete-account.tsx:25-32	Rename to [deleted]	deleted_at + backend job
sessionStore.ts:90	check_in_id: "	Actual UUID or null
progress.tsx:244-247	UUID substring as task name	Actual task title
GreetingHeader + others	[fire], [T], [S], [ok], [>] text	@expo/vector-icons
(tabs)/_layout.tsx:41-103	Letters H, P, C, S as tab icons	@expo/vector-icons
RevenueCat SDK	configure() never called	Add to _layout.tsx entry point

9. Security Risk Register

Severity	ID	Category	Description
[CRITICAL]	S1	Auth Bypass	Webhook signature skipped when secret unset
[CRITICAL]	S2	Race Condition	TOCTOU on rate limit allows unlimited AI calls
[CRITICAL]	S3	Race Condition	Shield award/use double-spend exploit
[CRITICAL]	S4	Fraud	Client-side subscription insertion
[HIGH]	S5	Prompt Injection	Unsanitized user data in AI system prompt
[HIGH]	S6	Privilege Escalation	Client can overwrite trust_score, shields
[HIGH]	S7	CORS	Wildcard * on all Edge Functions
[HIGH]	S8	Defense in Depth	Service functions lack user_id filters
[MEDIUM]	S9	Email Verification	enable_confirmations = false
[MEDIUM]	S10	Input Validation	No message length limits on AI endpoints
[MEDIUM]	S11	Data Integrity	pauses column type mismatch
[LOW]	S12	PII Exposure	User ID logged to console
[LOW]	S13	Type Safety	'system' role in TS but not DB CHECK

10. Test Coverage Analysis

Test Coverage: 0%

- Zero test files exist in the repository
- No test framework is installed (jest-expo, @testing-library/react-native, detox, maestro)
- No "test" script in package.json
- No test configuration files

Critical Untested Areas

- 1. Authentication flows — sign-in, sign-up, password reset, session management
- 2. Subscription entitlement logic — trial status, expiration, upgrade paths
- 3. Timer state machine — start, pause, resume, end, background restore
- 4. AI edge functions — rate limiting, prompt construction, error handling
- 5. Webhook processing — signature verification, event deduplication
- 6. Trust score calculation — EMA formula correctness
- 7. Shield award/use logic — boundary conditions, concurrent access
- 8. Check-in flow — energy level routing, AI task generation
- 9. Data integrity — FK constraints, type casting, null handling
- 10. Navigation guards — auth state routing, protected routes, deep links

11. Performance Risks

#	File	Issue	Impact
P1	sessions.service.ts:108	getSessionStats fetches ALL completed sessions	O(n) memory
P2	checkin.service.ts:42	getRecentCheckIns unbounded days param	Unbounded query
P3	promises.service.ts:65	getPromiseHistory unbounded	Unbounded query
P4	progress.tsx:784	ListHeaderComponent called on render	Re-renders on scroll
P5	shame-emergency.tsx:258	fetchEvidence() in render phase	Multiple fetches
P6	check-in.tsx:380	Components inside component body	Unmount/remount
P7	ai-chat/index.ts:210	No timeout on OpenAI fetch	Worker blocked 30s+
P8	ai-checkin/index.ts:281	Full system prompt per row	DB bloat
P9	useAppState.ts:31	Inline callbacks → listener churn	Event thrashing
P10	GreetingHeader.tsx:27	Date functions every render	Minor overhead

12. Refactoring Recommendations

Priority 1 — Pre-Launch Blockers

- Implement server-side subscription management — move trial creation to Edge Function, wire RevenueCat SDK
- Fix delete account — add deleted_at column, implement actual soft-delete + backend job
- Fix data export — implement backend export or downloadable file generation
- Add webhook signature fail-closed — reject when secret is absent
- Make rate limit atomic — Postgres function for counter increment with check
- Make shield operations atomic — Postgres RPCs for award and use
- Add update_streak trigger or RPC call — core feature is broken without it
- Bootstrap test suite — install jest-expo, write smoke tests for critical paths
- Add CI/CD — GitHub Actions + EAS Build configuration
- Configure RevenueCat — add Purchases.configure() to app entry

Priority 2 — Pre-Launch Important

- Restrict updateProfile — create ProfileUserUpdate type excluding gamification fields
- Add input validation — message length limits on AI endpoints
- Replace placeholder icons — install @expo/vector-icons
- Fix CORS — scope to app domain or remove from webhook
- Sanitize AI prompt inputs — separate user data from instructions
- Add error monitoring — integrate Sentry or similar
- Add .env to .gitignore — close the gap
- Add ownership filters — user_id in service functions alongside RLS

Priority 3 — Post-Launch Quality

- Consolidate timer logic — single source of truth (useTimer OR sessionStore)
- Remove legacy scaffold — Themed.tsx, Colors.ts, useClientOnlyValue*
- Remove unused deps — @react-native-async-storage/async-storage
- Fix type mismatches — pauses (JSONB vs number), system role, energy_level nullability
- Add ESLint + Prettier — enforce code quality
- Fix stale state issues — WELCOME_MESSAGE.created_at, getRelativeTime validation
- Extract components — move inline definitions out of screen bodies
- Add retry logic — exponential backoff on service calls

13. Files That Must Be Fixed

[CRITICAL] Must fix before any release

File	Issues
supabase/functions/revenuecat-webhook/index.ts	C1, C7, C8
supabase/functions/ai-chat/index.ts	C4, H2, H11
src/services/shields.service.ts	C5, C6
src/stores/sessionStore.ts	C9, M9
app/(onboarding)/trial-confirmation.tsx	C10
app/delete-account.tsx	C11
src/services/profile.service.ts	C11, H3, H4, M2
app/data-export.tsx	C12
supabase/migrations/001_initial_schema.sql	C13
src/types/database.ts	C8, M6, L8, L9

[HIGH] Must fix before production

File	Issues
app/paywall.tsx	H12
app/(tabs)/settings.tsx	H13, H27–H30
app/_layout.tsx	H14, M11
app/timer.tsx	H15, M19
app/(tabs)/progress.tsx	H16, H21
app/shame-emergency.tsx	H18
app/check-in.tsx	H19, M12
app/(auth)/sign-up.tsx	H20
supabase/functions/ai-checkin/index.ts	H9, H10, H11
src/services/sessions.service.ts	H8, M8

File	Issues
src/stores/chatStore.ts	H5, M27
src/services/chat.service.ts	H6
src/services/goals.service.ts	H7
.gitignore	H22

Verdict

FocusBuddy is not ready for production deployment.

The app has a solid architectural foundation and demonstrates thoughtful UX design (energy-aware coaching, shame detection, trust scoring). However, critical security vulnerabilities (webhook bypass, race conditions), non-functional features (paywall, delete account, data export, streaks), zero test coverage, and missing infrastructure (CI/CD, monitoring, linting) mean this codebase would fail a production readiness review at any major engineering organization.

Estimated effort to reach production readiness: 4–6 weeks of focused engineering work addressing the Priority 1 and Priority 2 items listed in Section 12.